

PCI DSS Compliance Enablement for a Fintech Organization

Background

A fintech organization required alignment with multiple PCI DSS requirements to continue providing secure payment services to its customers. At the time, the organization was working with a Managed Security Service Provider (MSSP) that handled infrastructure monitoring.

Following a migration of their environment to AWS, the client continued with the same MSSP. However, the quality of service began to decline. Communication gaps, delayed responses, and lack of clarity around compliance responsibilities led to increasing frustration.

As PCI DSS compliance timelines approached, the client realized they needed expert compliance guidance rather than managed monitoring services. Their key objective was to ensure PCI DSS alignment while retaining flexibility over their infrastructure and tooling.

With only four weeks available before the MSSP contract ended, the client approached SecComply to help them assess their environment, identify compliance gaps, and implement the necessary controls.

Client Environment Overview

The client's AWS-hosted infrastructure consisted of:

- 2 × Windows Server 2019 virtual machines
- 2 × Debian Linux virtual machines
- Active Directory server
- AWS CloudTrail
- pfSense firewall
- Microsoft Defender
- ClamAV antivirus

The environment required structured logging, audit readiness, and documented security controls to meet PCI DSS obligations.

SecComply's Role & Approach

SecComply engaged as a security and compliance consulting partner, focusing on:

- PCI DSS requirement mapping
- Security control assessment
- Logging and monitoring design
- Compliance documentation support
- Validation of technical controls

Phase 1: Discovery & Assessment

SecComply conducted a structured discovery session to understand:

- Business operations and working hours
- Administrative and privileged access
- Expected user behavior and access locations
- Third-party dependencies
- Current logging and monitoring practices
- Existing security policies and documentation

This allowed SecComply to build a clear picture of the client's risk posture and identify compliance gaps.

Phase 2: PCI DSS Gap Analysis & Advisory

PCI DSS Requirement 10 – Logging & Monitoring

SecComply reviewed the client's logging architecture and provided guidance to ensure compliance with:

- Centralized log collection
- Retention of audit logs
- Traceability of user and system actions

The client was advised on:

- What log sources must be enabled
- How long logs must be retained
- How to structure logs for audit readiness

Special focus was given to Requirement 10.7, ensuring:

- Minimum 90 days of immediately available logs

- At least 12 months of log retention for audit purposes

PCI DSS Requirement 11 – Security Testing & Change Monitoring

SecComply reviewed the client's vulnerability management and change detection processes.

Key advisory actions included:

- Validating quarterly vulnerability scan coverage
- Ensuring scan results were documented and reviewed
- Aligning scanning schedules with operational activities
- Advising on false-positive handling

To meet Requirement 11.5, SecComply guided the client on implementing:

- File Integrity Monitoring (FIM)
- Change detection for critical system files
- Alert review and documentation processes

These controls were designed to meet PCI DSS requirements without overengineering the environment.

Implementation Support & Validation

Rather than managing tools directly, SecComply worked alongside the client to:

- Review SIEM and log management configurations
- Validate alert logic and logging coverage
- Ensure documentation aligned with PCI DSS expectations
- Prepare evidence required for audits
- Define roles and responsibilities for incident handling

This ensured the client retained ownership of their environment while remaining compliant.

Results & Outcome

The engagement enabled the client to:

- **Successfully transition away from their previous MSSP**
- **Achieve PCI DSS-aligned logging and monitoring**
- **Implement structured vulnerability management**
- **Improve visibility across cloud and server environments**
- **Prepare audit-ready documentation**

Within the first month:

- **Over 25 million log events were validated for compliance coverage**
- **Legitimate system activities were clearly documented**
- **Change monitoring controls were confirmed operational**
- **Compliance gaps were closed without disrupting operations**

Client Feedback

The client appreciated SecComply's:

- **Clear and practical guidance**
- **Strong understanding of PCI DSS requirements**
- **Ability to translate compliance into actionable steps**
- **Vendor-neutral consulting approach**

They also confirmed their intent to continue working with SecComply as they move toward PCI DSS v4 compliance.

Why SecComply?

- ✓ **Independent security & compliance consultancy**
- ✓ **PCI DSS expertise**
- ✓ **Vendor-neutral recommendations**
- ✓ **Practical, audit-ready guidance**
- ✓ **Strong focus on risk reduction and clarity**

SecComply helped the client regain control of their compliance posture while ensuring long-term security and audit readiness — without unnecessary complexity.